

COMPTIA SECURITY+ SY0-701

TARGETED EXAM PREPARATION

100 High-Difficulty Scenario-Based Questions
With Detailed Answers and Explanations (Vietnamese Rationale)

Publisher: Gemini Notebook Agent

Date: August 2026

Version: 1.0 (SY0-701 Syllabus)

MỤC LỤC (TABLE OF CONTENTS)

Phần 1: Đề Thi Trắc Nghiệm Tiếng Anh (100 Questions)

- Domain 1: General Security Concepts (Q1 - Q12)	Trang 3
- Domain 2: Threats, Vulnerabilities, and Mitigations (Q13 - Q34)	Trang 4
- Domain 3: Security Architecture (Q35 - Q52)	Trang 6
- Domain 4: Security Operations and Forensics (Q53 - Q80)	Trang 8
- Domain 5: Security Program Management and Oversight (Q81 - Q100)	Trang 11
Phần 2: Đáp Án và Giải Thích Chi Tiết (Answers and Explanations)	Trang 14

DOMAIN 1: GENERAL SECURITY CONCEPTS

Question 1:

An organization is transitioning to a Zero Trust architecture. The Chief Information Security Officer (CISO) wants to ensure that all access requests are evaluated dynamically using a trust algorithm before access is granted to sensitive database resources. Which component of the Zero Trust Control Plane is responsible for making the final decision to grant or deny access based on contextual parameters?

- A. Policy Enforcement Point (PEP)
- B. Policy Administrator
- C. Policy Engine
- D. Gateway Agent

Question 2:

A retail company's website is defaced by attackers, who replaced the homepage with a political message. The core transactions and database remained intact, and no customer data was stolen. Which of the three primary cybersecurity objectives of the CIA triad was directly violated in this attack?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Non-repudiation

Question 3:

An administrator performs a monthly review of Active Directory group memberships to verify that users who have recently transferred departments do not retain unnecessary administrative access. Which control category and type best describe this administrative activity?

- A. Technical and Preventive
- B. Managerial and Detective
- C. Operational and Detective
- D. Operational and Preventive

Question 4:

Which of the following documents contains strictly mandatory high-level statements of management intent, establishing the overall security posture and allocating responsibilities across the organization, and must be signed off by executive leadership?

- A. Policy
- B. Standard
- C. Procedure
- D. Guideline

Question 5:

A security analyst conducts a risk assessment on a database server containing customer PII. The server has an estimated Asset Value (AV) of \$500,000. In the event of a successful SQL injection attack, the analyst estimates that the database will be 60% compromised. What is the Single Loss Expectancy (SLE) for this specific scenario?

- A. \$25,000
- B. \$200,000
- C. \$300,000
- D. \$500,000

Question 6:

A financial institution wants to protect credit card numbers stored in a transaction database. Instead of storing actual numbers, they replace each card number with a randomly generated 12-character alphanumeric identifier. The mapping between the original card number and the random identifier is maintained in a highly secure, centralized lookup table. Which data protection technique has been implemented?

- A. Hashing
- B. Masking
- C. Tokenization
- D. Redaction

Question 7:

A systems administrator needs to implement a security control that will discourage external attackers from attempting to breach the perimeter fence of a highly secure research facility. Which control type should the administrator focus on deploying?

- A. Detective
- B. Preventive
- C. Deterrent
- D. Corrective

Question 8:

A database administrator is configuring a customer database. The compliance department requires that customer service agents can view only the last four digits of a customer's Social Security Number (SSN) during phone support. The remaining digits should be replaced with asterisks (*). What technique should be applied?

- A. Hashing
- B. Tokenization
- C. Data Masking
- D. Data Destruction

Question 9:

A software developer is creating a digital signature for an application update. The developer wants to guarantee both authenticity and non-repudiation of the update package. Which cryptographic key must the developer use to create the digital signature?

- A. Developer's Private Key
- B. Developer's Public Key
- C. Recipient's Private Key
- D. Shared Symmetric Key

Question 10:

An organization's security policy prohibits employees from installing unauthorized applications on corporate laptops. To enforce this, the IT team deploys a software control that prevent any executable from running unless it is explicitly listed on an approved database. What category and type of control is this?

- A. Technical and Preventive
- B. Operational and Detective
- C. Managerial and Preventive
- D. Technical and Detective

Question 11:

A critical web application requires continuous session state verification to prevent session hijacking. The security team decides to mark all session cookies with specific attributes. Which cookie attribute ensures that the browser will never transmit the session cookie over an unencrypted HTTP connection?

- A. HttpOnly
- B. Secure
- C. SameSite
- D. Domain

Question 12:

Which of the following terms refers to the assurance that a specific transaction, message, or action was executed by a specific entity, and that the entity cannot later deny their involvement, typically implemented using asymmetric cryptography and digital signatures?

- A. Confidentiality
- B. Integrity
- C. Non-repudiation
- D. Availability

DOMAIN 2: THREATS, VULNERABILITIES, AND MITIGATIONS

Question 13:

A threat intelligence analyst is reviewing a feed that details an active malware campaign. The feed identifies an exploit that targets a vulnerability based on logical reasoning, but the exploit has not yet been observed in the wild or confirmed by an independent source. According to a standard six-level confidence rating, what confidence score range should this intelligence receive?

- A. 90-100 (Confirmed)
- B. 70-89 (Probable)
- C. 50-69 (Possible)
- D. 2-29 (Improbable)

Question 14:

A cyber defense team is setting up threat data exchange with external partners using the STIX 2.1 standard. They need to represent the connection between a specific Threat Actor and the Malware they use. Which STIX component is designed to represent this relationship?

- A. STIX Domain Object (SDO)
- B. STIX Relationship Object (SRO)
- C. TAXII Channel
- D. Cyber Observables

Question 15:

A security analyst in a SOC is consolidating cybersecurity feed data, software vulnerability advisories, and internal log events. The goal is to perform predictive analytics and detect complex, multi-stage intrusion patterns. What is this process called?

- A. Log Aggregation
- B. Intelligence Fusion
- C. Threat Hunting
- D. Vulnerability Mapping

Question 16:

During a security assessment, a network administrator notices that several servers are communicating with an external IP address on TCP port 6667. This port is historically associated with Internet Relay Chat (IRC). Further analysis reveals that the servers are receiving commands and downloading malicious payloads from this IP. What type of traffic is the administrator most likely observing?

- A. SQL Injection data exfiltration
- B. Botnet Command and Control (C&C;)
- C. Ransomware lateral movement
- D. Watering hole redirection

Question 17:

A piece of malicious software infects a system. It immediately begins scanning the local subnet for other hosts running a vulnerable version of the SMB service. Once found, it exploits the vulnerability over the network and copies itself to the target system, executing without any file attachments or human interaction. How should this malware be classified?

- A. Virus
- B. Trojan
- C. Worm
- D. Rootkit

Question 18:

An attacker has compromised a server. To maintain administrative access without triggering security alerts, the attacker installs a tool that intercepts calls to the operating system's kernel, hiding the attacker's files, processes, and active network connections from standard monitoring tools. Which type of malware has the attacker deployed?

- A. Trojan Horse
- B. Rootkit
- C. Backdoor
- D. Spyware

Question 19:

A customer service agent receives a call from an individual claiming to be the assistant of the company's CEO. The caller states that the CEO is in an urgent board meeting and needs their password reset immediately to access a critical presentation. The caller is highly aggressive and threatens HR escalation if the agent does not comply. Which social engineering technique is being utilized?

- A. Vishing and Pretexting
- B. Phishing and Typosquatting
- C. Smishing and Impersonation
- D. Watering Hole and Pretexting

Question 20:

A security engineer notices that a remote attacker has attempted to log into multiple administrative accounts across the enterprise by trying a single common password ('Summer2026!') against hundreds of different usernames. This technique allowed the attacker to bypass lock-out policies that trigger after three failed attempts on a single account. What type of attack has been detected?

- A. Brute-Force Attack
- B. Password Spraying
- C. Dictionary Attack
- D. Rainbow Table Attack

Question 21:

An organization installs new smart security cameras throughout its office. The security team fails to perform any configuration adjustments after installation. Attackers discover the cameras online and log into their control interfaces using publicly documented credentials provided by the manufacturer. Which vulnerability was exploited?

- A. Zero-Day Vulnerability
- B. Default Credentials
- C. Software Bug
- D. Legacy Firmware

Question 22:

A security researcher is analyzing a hashing algorithm. The researcher is trying to find mathematical vulnerabilities where two different, unique input values result in the exact same cryptographic hash output. What type of attack is the researcher attempting?

- A. Downgrade Attack
- B. Replay Attack
- C. Birthday Attack
- D. Collision Attack

Question 23:

An attacker intercepts wireless traffic and captures authentication handshakes. The attacker then attempts to crack the passwords offline by comparing the captured hashes against a massive database of precomputed hashes generated from common wordlists. What tool or asset is the attacker utilizing to speed up this process?

- A. Rainbow Table
- B. Active Sniffer
- C. Password Sprayer
- D. Keylogger

Question 24:

Which of the following threat actors is primarily motivated by ideological, political, or philosophical beliefs, often seeking to publicize their cause by defacing websites or leaking sensitive documents, and believes they are acting for the greater good?

- A. Organized Crime
- B. Hacktivist
- C. Shadow IT
- D. State-Sponsored Actor

Question 25:

An administrator discovers that a database server has been running an unapproved cloud-based file synchronization tool installed by a database developer to sync work projects to a personal device. The developer had no malicious intent and was simply trying to be productive. What risk concept does this represent?

- A. Insider Threat
- B. Shadow IT
- C. Espionage
- D. Social Engineering

Question 26:

A highly sophisticated attacker gains access to a corporate network. Over a period of several months, the attacker quietly maneuvers through the infrastructure, establishing multiple backdoors and gathering intellectual property while avoiding detection. How should this threat and behavior be classified?

- A. Script Kiddie
- B. Ransomware Campaign
- C. Advanced Persistent Threat (APT)
- D. Zero-Day Exploit

Question 27:

An attacker compromises a software vendor's automatic update server and injects a malicious backdoor into a legitimate software patch. When corporate clients download and install the official update, their internal systems are immediately compromised. What type of attack vector is this?

- A. Supply Chain Attack
- B. On-Path Attack
- C. Watering Hole Attack
- D. Sideload

Question 28:

A network security device is set to inspect traffic. If the device fails due to a hardware fault or power loss, it is configured to allow all network traffic to pass through unhindered to prevent business disruption, despite the loss of security filtering. What failure mode has been implemented?

- A. Fail-Closed
- B. Fail-Open
- C. Passive Tap
- D. Out-of-band

Question 29:

During an investigation, a security analyst discovers that an attacker registered several domain names that are common misspellings of the company's official website (e.g., 'g00gle.com' instead of 'google.com'). The attacker hosted clone login pages on these sites to harvest credentials. What is this attack called?

- A. Typosquatting
- B. Pretexting
- C. Domain Poisoning
- D. Whaling

Question 30:

An organization suffers an attack where the threat actor gained physical access to a public reception area and plugged a laptop into an open Ethernet port on the wall, bypassing the external firewall. What type of threat vector does this physical intrusion represent?

- A. Wireless Attack
- B. Supply Chain
- C. Direct Access / Wired Network
- D. Removable Device

Question 31:

A vulnerability management team identifies a vulnerability that has been published in the national database but has no patch or official fix available from the software vendor yet. What category of vulnerability does this represent?

- A. Legacy Platform
- B. Weak Configuration
- C. Zero-Day
- D. Insecure Protocol

Question 32:

Which of the following describes a psychological attack where an attacker attempts to influence opinions or reactions on social media by intentionally spreading false, inaccurate, or outright manipulated information to serve an adversarial goal?

- A. Misinformation
- B. Disinformation
- C. Malinformation
- D. Pretexting

Question 33:

A network security engineer wants to monitor network traffic entering a server rack. The engineer decides to deploy a device that makes a physical copy of the optical signal traveling through the fiber optic cables without needing any power source or interrupting the live connection. What device is the engineer using?

- A. Active Tap
- B. Passive Tap
- C. SPAN Port
- D. Inline Filter

Question 34:

Which security concept represents the original level of risk that exists within an organization's business processes before any security controls or risk response strategies are implemented?

- A. Residual Risk
- B. Inherent Risk
- C. Control Risk
- D. Accepted Risk

DOMAIN 3: SECURITY ARCHITECTURE

Question 35:

A cloud engineer is designing a secure network segment for an IaaS environment. The engineer wants to group a set of virtual machines into a private subnet that is completely isolated from direct incoming Internet connections, but still allows outbound connections via a NAT gateway. Which technology should the engineer use to implement this logical segmentation?

- A. Physical Firewall
- B. Virtual Private Cloud (VPC)
- C. Screened Subnet
- D. Software-Defined Network Controller

Question 36:

An organization wants to host a public Web Server. The security architecture requires that this server be accessible from the Internet, but completely isolated from the internal corporate database servers to prevent compromise from spreading. What network zone should the security team implement to host this server?

- A. Intranet
- B. Extranet
- C. Screened Subnet (DMZ)
- D. VLAN

Question 37:

A cloud security architect wants to enforce consistent security policies and compliance rules across all SaaS applications (like Office 365, Salesforce, and Box) used by the organization's employees. The architect wants to monitor user actions and block unencrypted file uploads. Which solution is best suited for this requirement?

- A. Next-Generation Firewall (NGFW)
- B. Secure Web Gateway (SWG)
- C. Cloud Access Security Broker (CASB)
- D. Host IPS

Question 38:

An application security developer wants to prevent SQL injection vulnerabilities. Instead of letting the application construct database queries dynamically by concatenating user inputs, the developer pre-compiles the SQL query template on the database server, leaving placeholders for parameters that are supplied later. What technique is this?

- A. Input Validation
- B. Data Encoding
- C. Parameterized Queries / Prepared Statements
- D. Stored Procedures

Question 39:

A security architect is reviewing the failure recovery plans for a critical database cluster. The database relies on replicating transactional logs in real time to a secondary server located in a geographically distant datacenter. If the primary database fails, the transactions must be immediately committed to the secondary database before returning success to the user. What replication model is this?

- A. Asynchronous Replication
- B. Synchronous Replication
- C. Journaling
- D. Snapshot Replication

Question 40:

An organization wants to configure high availability for their e-commerce web application. They implement a solution where incoming user traffic is distributed dynamically among four active web servers. If one server goes offline, the traffic is automatically routed to the remaining three. What high-availability design has been implemented?

- A. Active/Passive Clustering
- B. Active/Active Load Balancing
- C. Round-Robin DNS
- D. Cold Site Redundancy

Question 41:

A security engineer is setting up a secure network segment and wants to protect against layer 2 loop anomalies. If a user accidentally plugs both ends of an Ethernet cable into the same switch, which protocol is responsible for detecting the loop and disabling the offending port?

- A. Spanning Tree Protocol (STP)
- B. Bridge Protocol Data Unit (BPDU) Guard
- C. DHCP Snooping
- D. Quality of Service (QoS)

Question 42:

An organization wants to ensure that unauthorized DHCP servers (rogue DHCP) cannot be connected to the internal corporate network to hand out false IP configurations or perform on-path attacks. Which switch-level security feature should be implemented?

- A. BPDU Guard
- B. DHCP Snooping
- C. Port Security
- D. Dynamic ARP Inspection

Question 43:

A network architect is designing a secure remote access solution. The architect wants to implement a VPN tunnel that operates at Layer 3 (Network Layer) of the OSI model and encrypts all network packets sent between the remote client and the corporate gateway. Which technology should the architect select?

- A. SSL/TLS VPN
- B. IPSec VPN in Tunnel Mode
- C. SSH Tunneling
- D. SASE Gateway

Question 44:

An administrator wants to configure a VPN connection for traveling remote workers. The administrator wants to optimize bandwidth by allowing workers to access Internet services (like YouTube) directly through their local connection, while only routing corporate-bound traffic through the secure VPN tunnel. What configuration should the administrator apply?

- A. Full-Tunnel VPN
- B. Split-Tunnel VPN
- C. IPSec Transport Mode
- D. SSL Portal Mode

Question 45:

A software development company is adopting a cloud model where they can upload their application code functions (such as a database query trigger written in Python) to a cloud provider. The cloud provider executes the code only when triggered by specific events and handles all server provisioning, scaling, and system management transparently. What cloud model is this?

- A. Infrastructure as a Service (IaaS)
- B. Platform as a Service (PaaS) / Serverless FaaS
- C. Software as a Service (SaaS)
- D. Managed Service Provider (MSP)

Question 46:

An organization wants to implement a physical security system where an individual must present a valid credential to pass through a first door, which must close completely before a second door can be unlocked. What control is this, and which physical attack does it mitigate?

- A. Bollard; Vehicular Ramming
- B. Mantrap (Access Control Vestibule); Tailgating
- C. Biometric Scanner; RFID Cloning
- D. Faraday Cage; EMI Eavesdropping

Question 47:

A secure government facility wants to prevent electromagnetic signals from leaking out of its server room, block wireless signals (Wi-Fi, Cellular) from entering or exiting the room, and protect systems against external electromagnetic eavesdropping. What physical shield should be implemented?

- A. Industrial Camouflage
- B. Access Control Vestibule
- C. Faraday Cage
- D. Hot Aisle Containment

Question 48:

Which security concept states that an application or system should be designed with the capability to automatically and dynamically provision computing resources to scale up during peak demands, and automatically de-provision those resources to reduce capacity and cost when demand drops?

- A. Scalability
- B. Elasticity
- C. Redundancy
- D. High Availability

Question 49:

A company wants to secure its cloud storage buckets containing customer archives. Which of the following is the most critical architecture security consideration to ensure that automated crawlers cannot easily download the archives?

- A. Implementing high-availability replication
- B. Setting strict object-level access permissions and disallowing public access
- C. Enabling compression on block storage volumes
- D. Transitioning the storage format to virtual disks

Question 50:

Which of the following describes a hardware component installed in a server to create a hardware root of trust, providing secure cryptographic key generation, remote attestation of system boot state, and binding/sealing capabilities for disk encryption?

- A. Hardware Security Module (HSM)
- B. Trusted Platform Module (TPM)
- C. Secure Enclave
- D. Key Management System (KMS)

Question 51:

A database server must store extremely sensitive payment card transactions. The security team wants to run computations on the database records while they remain in an encrypted state, without ever needing to decrypt the data in memory. What emerging cryptographic technology supports this?

- A. Symmetric AES-GCM
- B. Homomorphic Encryption
- C. Lightweight Cryptography
- D. Quantum Key Distribution

Question 52:

A cloud security architect wants to write infrastructure configurations as code templates (using JSON or YAML) to automate the deployment of web servers, security groups, and load balancers consistently across multiple staging and production environments. What is this DevOps practice called?

- A. Continuous Deployment
- B. Infrastructure as Code (IaC)
- C. Package Monitoring
- D. Software-Defined Networking

DOMAIN 4: SECURITY OPERATIONS & FORENSICS

Question 53:

An incident responder is investigating a potential system compromise. The responder needs to quickly identify which internal servers made outbound network connections to a malicious external IP address over the weekend, the duration of each connection, and the volume of bytes transferred, without needing to inspect the packet payloads. Which log data source is best suited for this investigation?

- A. Full Packet Capture (PCAP)
- B. Network Flow (NetFlow/sFlow) logs
- C. Web Server logs
- D. DNS Query logs

Question 54:

According to the digital forensics Order of Volatility, which of the following system components holds the most volatile data and must be acquired or imaged first during a forensic investigation?

- A. System RAM
- B. CPU Registers and Cache
- C. Temporary files and Swap space
- D. Local Hard Disk Drive (HDD)

Question 55:

A security analyst is reviewing a SIEM dashboard and notices a series of login attempts for a single user account. The first login succeeded in Chicago at 09:00 AM, and a second login for the same account succeeded in Frankfurt, Germany, at 09:15 AM. Which indicator of compromise (IoC) has been flagged?

- A. Out-of-cycle logging
- B. Impossible Travel
- C. Concurrent Session Usage
- D. Missing Logs

Question 56:

A security operations team wants to ensure and enforce that all workstations have secure configurations matching the corporate security baseline. The team deploys a central management tool that actively monitors workstations for any unauthorized configuration changes and automatically reverts those changes back to the approved baseline. What is this process called?

- A. Baseline Validation
- B. Configuration Enforcement
- C. Patch Management
- D. Vulnerability Remediation

Question 57:

An organization is planning to conduct a vulnerability scan on a legacy mainframe that runs critical transaction processes. Due to the fragility of the mainframe, the security team is concerned that scanning could cause a service disruption. What is the most appropriate approach for the initial scan?

- A. Run an intrusive scan with dangerous plug-ins enabled on the production mainframe during peak hours.
- B. Run the scan in a representative non-production test environment.
- C. Do not scan the mainframe and accept all risks without evaluation.
- D. Run a non-credentialed external scan on the production network.

Question 58:

A security officer is documenting the chain of custody for a hard drive seized from a suspected insider. What is the primary purpose of maintaining a rigorous chain of custody during an investigation?

- A. To enable automated cloning of the drive using software write blockers.
- B. To prove that the evidence remained intact, unaltered, and properly monitored, ensuring its admissibility in court.
- C. To calculate the SHA-256 hash value of the disk image.
- D. To complete the processing stage of the Electronic Discovery Reference Model (EDRM).

Question 59:

During a computer forensic investigation, the examiner connects a seized USB thumb drive to an analysis workstation. The examiner wants to ensure that the operating system of the analysis workstation does not write any metadata or modify timestamps on the seized drive during the copy process. What tool must the examiner use?

- A. Software or Hardware Write Blocker
- B. Bit-by-bit Imager (dd)
- C. File Integrity Monitor
- D. Degausser

Question 60:

An investigator is attempting to recover files from a hard drive that was subjected to a quick format in Windows. What is the state of the data on the formatted drive?

- A. All sectors were completely overwritten with zeros, making the data unrecoverable.
- B. The file allocation index was deleted, but the actual file contents remain in the storage blocks until overwritten.
- C. The data was permanently destroyed using an electromagnetic degausser.
- D. Only the metadata remains, while the file contents are completely purged.

Question 61:

A network administrator is configuring network devices to send logs to a centralized server. The administrator wants to use a secure, modern logging protocol that supports high-speed message transfer, TCP-based delivery, and transport encryption via TLS. Which tool or service should the administrator implement?

- A. Standard Syslog on UDP 514
- B. Syslog-ng or Rsyslog
- C. SNMP Trap agent
- D. NXLog

Question 62:

A SOC analyst is tuning the correlation rules of a SIEM system because the analyst is receiving thousands of notifications a day for normal, scheduled network backups. What issue is the analyst experiencing, and what is the primary threat of not addressing it?

- A. False Negatives; missing actual intrusions
- B. Alert Fatigue; missing critical and high-priority alarms due to noise
- C. Log Aggregation error; database corruption in the SIEM
- D. Out-of-cycle logging; loss of network flow data

Question 63:

During an incident investigation, a security analyst reviews the web server log files and notices multiple HTTP GET requests containing the following string: 'GET /product.php?id=12 AND 1=2'. The request returned a blank page, confirming to the sender that the application is vulnerable. What type of attack was attempted?

- A. Reflected Cross-Site Scripting (XSS)
- B. Blind Content-Based SQL Injection
- C. Timing-Based SQL Injection
- D. Directory Traversal

Question 64:

An administrator discovers that a hacker managed to access the corporate web server and view the contents of the '/etc/passwd' file by entering the URL 'www.company.com/../../../../etc/passwd'. What vulnerability did the hacker exploit to perform this directory traversal?

- A. SQL Injection
- B. Insecure Direct Object Reference
- C. Directory Traversal and Weak Filesystem Permissions
- D. Remote File Inclusion

Question 65:

A security analyst discovers that an attacker is sending phishing emails to employees that contain a link mimicking the company's internal portal. When users click the link, they are directed to an external site hosted by the attacker, who stole their active session cookie. What attack has occurred?

- A. Session Hijacking via Session Replay
- B. Cross-Site Request Forgery (CSRF)
- C. SQL Injection
- D. Password Spraying

Question 66:

An organization wants to proactively identify security weaknesses, patch levels, and misconfigurations across their network-connected devices. Which tool should they run on a regular schedule to achieve this?

- A. Exploit Framework (Metasploit)
- B. Vulnerability Scanner (Nessus/Qualys)
- C. Port Scanner (Nmap)
- D. File Integrity Monitor (Tripwire)

Question 67:

A network administrator is reviewing switch logs and discovers that a port has been disabled because a user plugged in a personal switch, which started sending unauthorized Bridge Protocol Data Unit (BPDU) messages. Which protection feature was activated?

- A. Spanning Tree Protocol (STP)
- B. BPDU Guard
- C. Port Security
- D. Dynamic ARP Inspection

Question 68:

An incident response team is performing a post-mortem review of a major ransomware attack. The team wants to determine the underlying technical or administrative failure that allowed the initial compromise to occur, rather than just resolving the immediate symptoms. What process is the team executing?

- A. Threat Hunting
- B. Lessons Learned and Root Cause Analysis (RCA)
- C. Incident Eradication
- D. Vulnerability Classification

Question 69:

Which of the following describes an active security testing exercise where a certified security professional is authorized to simulate a real-world cyberattack against an organization's systems to evaluate the effectiveness of their overall defensive posture?

- A. Security Audit
- B. Penetration Test
- C. Vulnerability Scan
- D. Risk Control Assessment

Question 70:

A penetration tester is given network diagrams, IP address ranges, and administrative credentials for all servers in the target environment before the engagement begins. What classification best describes this penetration test?

- A. Unknown Environment (Black box)
- B. Partially Known Environment (Gray box)
- C. Known Environment (White box)
- D. Zero Knowledge Test

Question 71:

A security analyst wants to verify if an attacker has modified critical operating system binaries (such as system DLLs or host files) on a Windows server. Which security tool or capability is designed to monitor and alert on changes to files on disk?

- A. Host-based Firewall
- B. File Integrity Monitor (FIM)
- C. Endpoint Detection and Response (EDR)
- D. Antivirus scan

Question 72:

An organization wants to test the coordination and communication flow of its incident response team during a simulated ransomware crisis. The team gathers in a conference room and walks through the response playbook step-by-step using a hypothetical scenario, without making any changes to production systems. What exercise is this?

- A. Simulation
- B. Parallel Processing
- C. Tabletop Exercise
- D. Failover Exercise

Question 73:

A forensic examiner wants to ensure that a captured memory dump file remains untampered and verified throughout the entire analysis process. What mathematical calculation should the examiner perform immediately after capturing the dump?

- A. Generating a cryptographic hash (MD5/SHA-256) of the dump file
- B. Creating a backup image using a write blocker
- C. Performing a quick format on the target drive
- D. Uploading the file to a public malware scanning database

Question 74:

A system administrator is configuring authentication for network switches. The administrator wants a protocol that completely encrypts all packet payloads (not just passwords), uses TCP for reliable transport, and fully separates Authentication, Authorization, and Accounting (AAA) functions. Which protocol is best suited?

- A. RADIUS
- B. TACACS+
- C. Kerberos
- D. LDAP

Question 75:

During an incident, the responder decides to block all traffic coming from a specific subnet that is identified as the source of a port scanning attack. The responder implements a rule on the perimeter router to drop all packets from this subnet. What action did the responder take?

- A. Isolation
- B. Containment via Access Control List (ACL)
- C. Eradication via Backup
- D. Threat Scope Reduction

Question 76:

An organization wants to incentivize external independent security researchers to discover and securely report vulnerabilities in their public web applications in exchange for financial rewards. What program should the organization establish?

- A. Responsible Disclosure Program
- B. Bug Bounty Program
- C. Independent Third-Party Audit
- D. Vulnerability Lifecycle Management

Question 77:

Which forensic concept describes the notice sent by legal counsel requiring an organization to preserve all electronic records, backups, and metadata related to an ongoing or anticipated legal case, preventing spoliation of evidence?

- A. e-Discovery
- B. Legal Hold
- C. Chain of Custody
- D. Attestation

Question 78:

A forensic analyst is analyzing a file's metadata. The analyst wants to find information about when the file was originally created, modified, the author of the file, and potentially the GPS coordinates of the camera that took it. What tool is designed to extract this embedded information?

- A. ExifTool
- B. FTK Imager
- C. WinHex
- D. dd

Question 79:

Which of the following describes the process of systematically searching through an organization's network and computing resources to find active, undetected attackers who have already bypassed perimeter defenses, operating on a presumption of compromise?

- A. Penetration Testing
- B. Vulnerability Scanning
- C. Threat Hunting
- D. Security Auditing

Question 80:

A database server has crashed due to hardware failure. The recovery team calculates that it took an average of 4 hours to repair the hardware and restore the database services back to normal operation. Which metric does this 4-hour window represent?

- A. Mean Time to Repair (MTTR)
- B. Mean Time Between Failures (MTBF)
- C. Recovery Time Objective (RTO)
- D. Recovery Point Objective (RPO)

DOMAIN 5: SECURITY PROGRAM MANAGEMENT AND OVERSIGHT

Question 81:

A security manager is writing a document that specifies the exact technical requirements, such as requiring the use of AES-256 encryption on all storage devices. Compliance with this document is strictly mandatory for all employees. What type of document is this?

- A. Policy
- B. Standard
- C. Procedure
- D. Guideline

Question 82:

An organization wants to establish an agreement with a cloud vendor that specifies the minimum guaranteed uptime of 99.99% for hosted services, and defines the financial penalties the vendor will face if they fail to meet this threshold. Which agreement should be used?

- A. Master Service Agreement (MSA)
- B. Service Level Agreement (SLA)
- C. Memorandum of Understanding (MOU)
- D. Business Partners Agreement (BPA)

Question 83:

Under the GDPR compliance framework, which of the following roles represents the entity that determines the purposes, justifications, and methods of processing personal data, bearing the ultimate responsibility for data privacy compliance?

- A. Data Subject
- B. Data Controller
- C. Data Processor
- D. Data Steward

Question 84:

A hospital system wants to assess its compliance with the legal requirements for securing patient medical records. Which regulation should the hospital align its compliance program with?

- A. GDPR
- B. PCI DSS
- C. HIPAA
- D. FERPA

Question 85:

Which risk management strategy is an organization adopting when they purchase a cyber-liability insurance policy to cover the financial losses resulting from potential ransomware attacks?

- A. Risk Avoidance
- B. Risk Mitigation
- C. Risk Transference
- D. Risk Acceptance

Question 86:

A company wants to completely eliminate the risk of customer credit card data breach from their systems. They decide to stop accepting credit card payments entirely, transitioning to a model that accepts only direct bank transfers. Which risk management strategy has been implemented?

- A. Risk Mitigation
- B. Risk Avoidance
- C. Risk Transference
- D. Risk Acceptance

Question 87:

A security manager is assessing the risk of power outages at a datacenter. The manager implements a redundant power supply system with a generator and UPS. Despite this control, the manager acknowledges that a prolonged blackout exceeding 48 hours could still cause an outage. What term describes this remaining level of risk?

- A. Inherent Risk
- B. Residual Risk
- C. Control Risk
- D. Accepted Risk

Question 88:

An organization's executive board is aggressive and willing to take on high levels of cybersecurity risk in the pursuit of rapid product innovation and capturing market share. Which term best describes this overall attitude toward risk?

- A. Conservative Risk Appetite
- B. Neutral Risk Appetite
- C. Expansionary Risk Appetite
- D. Low Risk Tolerance

Question 89:

Which risk register element represents the specific quantitative or qualitative boundary at which a risk becomes unacceptable, immediately triggering an escalation or remediation action?

- A. Key Risk Indicator (KRI)
- B. Risk Owner
- C. Risk Threshold
- D. Risk Appetite

Question 90:

A security team conducts an annual audit of third-party vendors. The contract with a SaaS vendor includes a clause that permits the organization's independent auditors to physically enter the vendor's datacenters and inspect their security practices. What is this clause called?

- A. Service Level Agreement
- B. Non-Disclosure Agreement
- C. Right-to-Audit Clause
- D. Master Service Agreement

Question 91:

An organization wants to formally document a collaborative, non-binding relationship with another agency to share threat intelligence and establish mutual understandings without entering into a legally binding contract. Which document should they use?

- A. Master Service Agreement (MSA)
- B. Memorandum of Understanding (MOU)
- C. Service Level Agreement (SLA)
- D. Non-Disclosure Agreement (NDA)

Question 92:

A security analyst is preparing a quarterly risk report for the executive board. What is the most effective visual tool the analyst should use to summarize the probability and impact of corporate risks for senior leadership?

- A. Raw SQL log tables
- B. Risk Register spreadsheet
- C. Risk Matrix (Heat Map)
- D. Incident Response Playbook

Question 93:

The legal department of a software company drafts an agreement requiring employees and vendors to protect the confidentiality of proprietary source code they have access to during their employment or partnership. What is this contract called?

- A. Service Level Agreement (SLA)
- B. Non-Disclosure Agreement (NDA)
- C. Business Partners Agreement (BPA)
- D. Statement of Work (SOW)

Question 94:

Which regulatory standard applies worldwide to all merchants, financial institutions, and service providers that store, process, or transmit credit card and debit card information, enforced through contractual penalties rather than federal laws?

- A. HIPAA
- B. PCI DSS
- C. GDPR
- D. FERPA

Question 95:

An organization wants to formally evaluate the security baseline of its Active Directory configuration against industry-accepted secure benchmarks developed by consensus of security experts. Which resource should the organization consult?

- A. OWASP Top 10
- B. CIS Benchmarks
- C. ISO 27701
- D. HIPAA Security Rule

Question 96:

A university wants to ensure that student academic records and grades are protected from unauthorized disclosure, in compliance with federal privacy laws in the United States. Which regulation governs this requirement?

- A. HIPAA
- B. FERPA
- C. PCI DSS
- D. GDPR

Question 97:

An organization's security awareness team is launching a program where they send fake phishing emails to employees. Employees who fall for the trick and click on the link are immediately redirected to a short training module. What is this security practice called?

- A. Anti-phishing Campaign / Phishing Simulation
- B. Penetration Testing
- C. Responsible Disclosure
- D. Anomalous Behavior Recognition

Question 98:

A security team is implementing a personnel security policy. The policy forces employees in highly sensitive accounting roles to take consecutive days of time off annually, during which their system access is completely revoked, to allow any potential fraudulent activity to be discovered. What control is this?

- A. Separation of Duties
- B. Job Rotation
- C. Mandatory Vacations
- D. Dual Control

Question 99:

Which of the following standards published by the International Organization for Standardization (ISO) specifies the requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS)?

- A. ISO 27001
- B. ISO 27002
- C. ISO 27701
- D. ISO 31000

Question 100:

An organization wants to define a standard, step-by-step checklist of actions that the incident response team must follow when responding to a specific type of incident, such as a SQL injection attack on the corporate website. What type of document is this?

- A. Policy
- B. Standard
- C. Procedure / Playbook
- D. Guideline

ĐÁP ÁN VÀ GIẢI THÍCH CHI TIẾT (ANSWERS AND RATIONALE)

Dưới đây là đáp án chính thức và phần lập luận chi tiết bằng tiếng Việt giúp bạn hiểu sâu bản chất từng câu hỏi tình huống phức tạp.

Question 1: Domain 1: General Security Concepts

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Policy Engine (Công cụ chính sách) là 'bộ não' của kiến trúc Zero Trust, sử dụng thuật toán tin cậy để đưa ra quyết định cuối cùng về việc cho phép hay từ chối một yêu cầu truy cập dựa trên chính sách và ngữ cảnh. Policy Administrator thực thi quyết định bằng cách gửi lệnh cấu hình đến Policy Enforcement Point (PEP) để thực tế đóng/mở kết nối.

Question 2: Domain 1: General Security Concepts

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Tính toàn vẹn (Integrity) đảm bảo thông tin và hệ thống không bị thay đổi trái phép. Việc trang web bị deface (thay đổi giao diện) là hành vi sửa đổi trái phép trang chủ, trực tiếp vi phạm tính toàn vẹn. Dữ liệu không bị rò rỉ (Confidentiality không bị ảnh hưởng) và trang web vẫn hoạt động (Availability không bị sập).

Question 3: Domain 1: General Security Concepts

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Kiểm tra quyền truy cập (User access review) định kỳ là một hoạt động thuộc nhóm kiểm soát vận hành (Operational control) vì nó liên quan đến quy trình vận hành bảo mật do con người thực hiện hàng ngày/tháng. Đây là loại kiểm soát phát hiện (Detective) vì nó tìm kiếm và xác định các sai sót cấu hình tích lũy quyền hạn (privilege creep) đã xảy ra.

Question 4: Domain 1: General Security Concepts

Correct Answer: A

Lập luận chi tiết (Vietnamese Explanation): Chính sách (Policy) là văn bản bắt buộc cấp cao nhất, phản ánh định hướng và cam kết của ban quản trị tối cao đối với an ninh thông tin. Các văn bản khác như Standard quy định kỹ thuật cụ thể, Procedure hướng dẫn từng bước và Guideline chỉ mang tính khuyến nghị không bắt buộc.

Question 5: Domain 1: General Security Concepts**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Single Loss Expectancy (SLE) là kỳ vọng mất mát đơn lẻ cho mỗi lần rủi ro xảy ra. Công thức: $SLE = \text{Asset Value (AV)} * \text{Exposure Factor (EF)}$. Ở đây, $AV = \$500,000$ và $EF = 60\% (0.60)$. Vậy $SLE = \$500,000 * 0.60 = \$300,000$.

Question 6: Domain 1: General Security Concepts**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Token hóa (Tokenization) là kỹ thuật thay thế dữ liệu nhạy cảm bằng một giá trị định danh ngẫu nhiên (token). Điểm mấu chốt của Tokenization là sử dụng một bảng tra cứu (lookup table) bảo mật để ánh xạ ngược lại dữ liệu gốc khi cần, làm cho quy trình này hoàn toàn khả nghịch (reversible) đối với những người có thẩm quyền.

Question 7: Domain 1: General Security Concepts**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Kiểm soát răn đe (Deterrent control) nhằm mục đích làm giảm ý muốn tấn công của kẻ xấu bằng cách cảnh báo về những hậu quả bất lợi hoặc độ khó cao (ví dụ: treo biển cảnh báo chó dữ, lắp rào kẽm gai). Nó khác với Preventive (ngăn chặn trực tiếp) hay Detective (phát hiện khi đã xảy ra).

Question 8: Domain 1: General Security Concepts**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Che dấu dữ liệu (Data Masking) thay thế một phần dữ liệu bằng các ký tự giữ chỗ như '*' hoặc 'X' để bảo vệ thông tin nhạy cảm khi hiển thị trên màn hình cho người dùng không cần toàn bộ dữ liệu. Nó khác với Hashing (mã hóa một chiều toàn bộ chuỗi) và Tokenization (thay thế bằng mã token).

Question 9: Domain 1: General Security Concepts**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Để tạo chữ ký số (Digital Signature) đảm bảo tính chống chối bỏ (non-repudiation) và tính xác thực (authenticity), người ký phải dùng Khóa riêng tư (Private Key) của chính họ để mã hóa hàm băm của tệp tin. Người nhận sẽ dùng Khóa công khai (Public Key) tương ứng để giải mã và kiểm tra.

Question 10: Domain 1: General Security Concepts

Correct Answer: A

Lập luận chi tiết (Vietnamese Explanation): Kiểm soát cho phép chạy ứng dụng (Application Allow List) được cấu hình bằng phần mềm/hệ điều hành, do đó thuộc nhóm Kiểm soát kỹ thuật (Technical control). Nó trực tiếp ngăn chặn việc cài đặt phần mềm không hợp lệ từ trước khi xảy ra, nên là kiểm soát Ngăn chặn (Preventive).

Question 11: Domain 1: General Security Concepts

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Thuộc tính 'Secure' trên cookie yêu cầu trình duyệt chỉ được phép truyền cookie này thông qua các kết nối được mã hóa bằng SSL/TLS (HTTPS), ngăn chặn việc truyền tải qua HTTP rõ có thể bị nghe lén (on-path attack). 'HttpOnly' ngăn mã script phía client tiếp cận cookie.

Question 12: Domain 1: General Security Concepts

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Tính chống chối bỏ (Non-repudiation) đảm bảo rằng một thực thể đã thực hiện hành động không thể phủ nhận việc đó sau này. Chữ ký số là kỹ thuật chính để thực hiện tính chống chối bỏ nhờ sự kết hợp giữa hàm băm một chiều và khóa riêng tư duy nhất của người ký.

Question 13: Domain 2: Threats, Vulnerabilities, and Mitigations

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Mức độ 'Probable' (Có khả năng - từ 70 đến 89) được chỉ định khi thông tin tình báo dựa trên suy luận logic chặt chẽ nhưng chưa có xác nhận thực tế độc lập trực tiếp. Nếu có nguồn tin độc lập xác nhận trực tiếp thì sẽ xếp vào mức 'Confirmed' (90-100).

Question 14: Domain 2: Threats, Vulnerabilities, and Mitigations

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): STIX 2.1 sử dụng các đối tượng quan hệ STIX (STIX Relationship Objects - SROs) để thiết lập và mô tả các mối liên kết hoặc sự kiện quan sát được (sighting) giữa các đối tượng domain khác nhau (SDOs), chẳng hạn như liên kết giữa tác nhân đe dọa (Threat Actor) và mã độc (Malware).

Question 15: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Hợp nhất thông tin tình báo (Intelligence Fusion) là quá trình thu thập, tích hợp và phân tích dữ liệu đe dọa từ nhiều nguồn khác nhau (cả bên ngoài và bên trong) để phát hiện ra các mẫu tấn công phức tạp mà một nguồn đơn lẻ không thể nhận biết.

Question 16: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Mạng botnet thường sử dụng giao thức IRC (cổng 6667) để thiết lập kênh liên lạc và ra lệnh (Command and Control - C&C;) từ máy chủ điều khiển (botmaster) đến các máy nạn nhân (bots). Khi thấy hệ thống tự động kết nối ra cổng 6667, đó là dấu hiệu điển hình của botnet.

Question 17: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Sâu máy tính (Worm) là loại mã độc có khả năng tự sao chép (self-replicating) và tự động lây lan qua mạng bằng cách khai thác các dịch vụ bị lỗi mà không cần bất kỳ sự tương tác nào của người dùng hay tệp vật chủ. Virus yêu cầu tệp vật chủ và sự tương tác của người dùng để kích hoạt.

Question 18: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Rootkit là loại mã độc được thiết kế chuyên biệt để can thiệp sâu vào nhân hệ điều hành (kernel) hoặc các trình điều khiển hệ thống nhằm che giấu (cloak) sự hiện diện của chính nó và các tiến trình độc hại khỏi các công cụ quét bảo mật thông thường. Backdoor chỉ là lối vào từ xa, không có tính năng che giấu cấp nhân.

Question 19: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Cuộc gọi lừa đảo qua điện thoại là Vishing. Việc dựng lên một kịch bản giả định (trợ lý CEO đang họp khẩn) để lừa nạn nhân là Pretexting. Kẻ tấn công cũng áp dụng nguyên lý uy quyền (authority) và sự uy hiếp (intimidation).

Question 20: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Password Spraying (phun mật khẩu) là biến thể của brute-force, thử nghiệm một vài mật khẩu phổ biến trên một danh sách rất lớn các tài khoản để tránh kích hoạt cơ chế khóa tài khoản (lockout policy) vốn thường kích hoạt khi nhập sai mật khẩu nhiều lần trên một tài khoản duy nhất.

Question 21: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Mật khẩu mặc định (Default Credentials) là lỗi cấu hình cực kỳ phổ biến và nghiêm trọng, đặc biệt với các thiết bị IoT. Kẻ tấn công chỉ cần quét IP và thử các tài khoản/mật khẩu mặc định được nhà sản xuất công bố công khai trên Internet để truy cập hệ thống trái phép.

Question 22: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: D**

Lập luận chi tiết (Vietnamese Explanation): Tấn công va chạm (Collision Attack) là hành vi tìm kiếm hai đầu vào khác nhau tạo ra cùng một giá trị băm. Khi một thuật toán băm bị chứng minh là dễ bị tấn công và va chạm (như MD5), nó sẽ bị coi là không an toàn cho mục đích kiểm tra toàn vẹn hoặc chữ ký số. Birthday Attack là một dạng toán học của tấn công va chạm.

Question 23: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Bảng cầu vồng (Rainbow Table) là một cơ sở dữ liệu được tính toán trước (precomputed) chứa các cặp chuỗi văn bản rõ và giá trị băm tương ứng. Nó giúp kẻ tấn công rút ngắn thời gian giải mã băm thu giữ được bằng cách tra cứu trực tiếp thay vì phải tính toán băm thời gian thực.

Question 24: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Tin tặc hoạt động vì mục đích chính trị/xã hội (Hacktivist) là nhóm tin tặc bị thúc đẩy bởi niềm tin hệ tư tưởng hoặc triết học, thực hiện các cuộc tấn công mạng để quảng bá cho một phong trào hoặc phản đối một chính sách nào đó.

Question 25: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Shadow IT (Công nghệ thông tin bóng tối) đề cập đến việc nhân viên tự ý sử dụng các hệ thống, thiết bị hoặc phần mềm dịch vụ đám mây không được phê duyệt chính thức bởi bộ phận IT của tổ chức, nhằm mục đích tăng năng suất công việc nhưng vô tình gây rủi ro bảo mật lớn.

Question 26: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Mối đe dọa nâng cao và dai dẳng (Advanced Persistent Threat - APT) thường đại diện cho các nhóm tin tặc có kỹ năng cao, được tài trợ lớn (thường là cấp quốc gia), thực hiện các cuộc tấn công kiên trì và tinh vi kéo dài nhiều tháng/năm nhằm đánh cắp thông tin bí mật.

Question 27: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Tấn công chuỗi cung ứng (Supply Chain Attack) xảy ra khi kẻ tấn công can thiệp vào các mắt xích cung cấp phần cứng, phần mềm hoặc dịch vụ của bên thứ ba (ở đây là bản cập nhật chính thức của nhà cung cấp) để gián tiếp xâm nhập vào mạng lưới của khách hàng.

Question 28: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Chế độ Fail-Open (thất bại mở) cấu hình hệ thống sao cho khi thiết bị bảo mật bị lỗi hoặc mất điện, nó sẽ tự động cho phép mọi dữ liệu đi qua mà không lọc, ưu tiên tính sẵn sàng của kinh doanh hơn tính bảo mật. Ngược lại, Fail-Closed sẽ chặn mọi lưu lượng.

Question 29: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Typosquatting (chiếm đoạt tên miền do gõ lỗi) là kỹ thuật kẻ tấn công đăng ký các tên miền có lỗi chính tả gần giống với tên miền hợp lệ của tổ chức nhằm vào những người dùng gõ sai URL, sau đó dùng các trang này để lừa đảo thu thập thông tin đăng nhập.

Question 30: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Kênh truy cập trực tiếp (Direct Access) hoặc tấn công mạng có dây là việc kẻ tấn công tiếp cận vật lý với cơ sở hạ tầng mạng bên trong (như cổng mạng tường phòng khách) để cắm thiết bị trực tiếp vào phân đoạn mạng nội bộ, bỏ qua các chốt chặn biên.

Question 31: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Lỗ hổng Zero-day là lỗ hổng phần mềm chưa được biết đến rộng rãi hoặc chưa có bản vá từ nhà cung cấp. Ngay cả khi đã được công bố nhưng chưa có bản vá chính thức, hệ thống bị khai thác sẽ không có phương thức sửa lỗi trực tiếp ngoài việc áp dụng các biện pháp giảm thiểu bù đắp.

Question 32: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Thông tin sai lệch cố ý (Disinformation) là thông tin sai lệch hoặc bị thao túng được cố tình tạo ra và lan truyền nhằm mục đích đánh lừa, định hướng dư luận hoặc gây hại cho một mục tiêu cụ thể. Nó khác với Misinformation (thông tin sai lệch vô ý do hiểu sai sự thật).

Question 33: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Passive Tap (Thiết bị phân tách tín hiệu thụ động) không yêu cầu nguồn điện hoạt động, hoạt động bằng cách phân tách ánh sáng vật lý trong cáp quang để tạo ra bản sao dữ liệu giám sát, đảm bảo rằng ngay cả khi thiết bị giám sát hỏng, kết nối mạng gốc vẫn không bị gián đoạn.

Question 34: Domain 2: Threats, Vulnerabilities, and Mitigations**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Rủi ro vốn có (Inherent Risk) là mức độ rủi ro tự nhiên tồn tại trong hoạt động của tổ chức khi chưa áp dụng bất kỳ biện pháp kiểm soát nào để giảm thiểu rủi ro đó. Rủi ro còn lại sau khi áp dụng kiểm soát gọi là Residual Risk.

Question 35: Domain 3: Security Architecture

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Virtual Private Cloud (VPC) là giải pháp phân đoạn logic cốt lõi trong môi trường điện toán đám mây (IaaS), cho phép chia mạng thành các mạng con (subnet) công cộng và riêng tư để cô lập và bảo vệ tài nguyên tính toán khỏi Internet.

Question 36: Domain 3: Security Architecture

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Vùng đệm an toàn / Mạng con sàng lọc (Screened Subnet hoặc DMZ) là vùng kiến trúc mạng chuyên biệt được thiết kế để chứa các dịch vụ hướng ra công chúng (như Web Server). Nó nằm giữa Internet và mạng nội bộ, được kiểm soát bởi tường lửa để ngăn chặn tấn công lan rộng vào nội bộ.

Question 37: Domain 3: Security Architecture

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Công cụ giám sát và thực thi chính sách đám mây (Cloud Access Security Broker - CASB) hoạt động như một bộ lọc trung gian giữa người dùng và các dịch vụ đám mây (đặc biệt là SaaS), giúp thực thi các chính sách bảo mật như mã hóa, ngăn rò rỉ dữ liệu (DLP) và kiểm soát truy cập đồng nhất.

Question 38: Domain 3: Security Architecture

Correct Answer: C

Lập luận chi tiết (Vietnamese Explanation): Truy vấn tham số hóa (Parameterized Queries hay Prepared Statements) là biện pháp chống SQLi hiệu quả nhất. Nó tách biệt hoàn toàn phần mã lệnh SQL (đã biên dịch trước) và phần dữ liệu tham số do người dùng nhập vào, khiến công cụ cơ sở dữ liệu không bao giờ thực thi dữ liệu đầu vào như một lệnh.

Question 39: Domain 3: Security Architecture

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Sao chép đồng bộ (Synchronous Replication) ghi dữ liệu đồng thời vào cả hai địa điểm (gốc và sao lưu) trước khi xác nhận hoàn thành giao dịch, đảm bảo dữ liệu luôn khớp nhau hoàn hảo ở mọi thời điểm, tối thiểu hóa RPO về 0. Asynchronous thực hiện việc sao chép sau một khoảng trễ.

Question 40: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Cân bằng tải chủ động/chủ động (Active/Active Load Balancing) phân phối lưu lượng truy cập thực tế đến nhiều nút đang cùng hoạt động trực tuyến, vừa tăng hiệu năng xử lý vừa cung cấp tính sẵn sàng cao bằng cách tự động loại bỏ các nút lỗi khỏi nhóm.

Question 41: Domain 3: Security Architecture**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Giao thức cây bao trùm (Spanning Tree Protocol - STP) là giao thức tầng liên kết dữ liệu giúp phát hiện các vòng lặp vật lý (loops) trong cấu trúc mạng switch và tự động vô hiệu hóa các cổng thừa để ngăn chặn thảm họa 'bão quảng bá' (broadcast storm).

Question 42: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): DHCP Snooping là tính năng bảo mật trên switch, xác định các cổng đáng tin cậy (trusted) kết nối với DHCP server hợp lệ và chặn đứng tất cả các thông điệp phản hồi cấp IP phát ra từ các cổng không đáng tin cậy (untrusted), ngăn ngừa thiết lập DHCP giả mạo.

Question 43: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): IPSec VPN ở chế độ đường hầm (Tunnel Mode) hoạt động ở Tầng 3, đóng gói toàn bộ gói tin IP gốc (bao gồm cả header) vào một gói tin IP mới được mã hóa và ký số bảo vệ, phù hợp cho việc mở rộng kết nối mạng toàn diện và site-to-site.

Question 44: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Đường hầm phân chia (Split-Tunnel VPN) chỉ định tuyến lưu lượng dành riêng cho mạng nội bộ đi qua kết nối mã hóa VPN, các lưu lượng Internet khác đi trực tiếp qua mạng cục bộ của người dùng để tiết kiệm băng thông cho cổng VPN của công ty.

Question 45: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Điện toán không máy chủ (Serverless) hay Hàm như một dịch vụ (Function as a Service - FaaS) là một mô hình PaaS nâng cao, nơi người dùng chỉ quản lý các đoạn mã nguồn (functions) và tài nguyên chạy mã được cấp phát và co giãn hoàn toàn tự động bởi nhà cung cấp đám mây.

Question 46: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Cửa kiểm soát hai lớp (Mantrap hay Access Control Vestibule) bắt buộc cửa đầu tiên phải đóng hẳn trước khi cửa thứ hai mở, ngăn chặn trực tiếp hành vi đi theo đuôi (tailgating hay piggybacking) của những kẻ không có thẩm quyền.

Question 47: Domain 3: Security Architecture**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Lồng Faraday (Faraday Cage) là một lớp chắn vật lý bằng vật liệu dẫn điện giúp ngăn chặn các điện trường và sóng điện từ (Wi-Fi, di động, bức xạ thiết bị) đi qua, bảo vệ thông tin chống lại việc nghe lén sóng vô tuyến rò rỉ.

Question 48: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Tính đàn hồi (Elasticity) là khả năng của hệ thống tự động co giãn (tăng và giảm) tài nguyên tính toán theo thời gian thực phù hợp với nhu cầu sử dụng thực tế. Scalability (tính khả giãn) tập trung vào việc có thể nâng cấp quy mô lớn hơn.

Question 49: Domain 3: Security Architecture**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Cấu hình sai quyền truy cập (Improper permissions) trên các thùng chứa dữ liệu đám mây (Cloud storage buckets) là nguyên nhân hàng đầu gây lộ dữ liệu. Việc đặt quyền truy cập nghiêm ngặt và cấm truy cập công khai (public) là rào cản quan trọng nhất để chống quét tự động.

Question 50: Domain 3: Security Architecture

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Trusted Platform Module (TPM) là một chip phần cứng chuyên biệt được hàn trực tiếp lên bo mạch chủ để thiết lập điểm gốc tin cậy phần cứng (hardware root of trust), hỗ trợ băm kiểm tra trạng thái khởi động (measured boot) và lưu trữ khóa mã hóa đĩa.

Question 51: Domain 3: Security Architecture

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Mã hóa đồng cấu (Homomorphic Encryption) cho phép thực hiện các phép tính toán học trực tiếp trên dữ liệu đang bị mã hóa. Kết quả sau khi giải mã sẽ trùng khớp chính xác với kết quả nếu ta tính toán trên dữ liệu rõ, bảo vệ tối đa tính riêng tư.

Question 52: Domain 3: Security Architecture

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Hạ tầng dưới dạng mã (Infrastructure as Code - IaC) cho phép định nghĩa và quản lý tài nguyên phần cứng, mạng và bảo mật thông qua các tệp mã nguồn (như JSON, YAML), tự động hóa việc triển khai hệ thống đồng nhất và giảm thiểu sai sót do con người.

Question 53: Domain 4: Security Operations & Forensics

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Dữ liệu luồng mạng (NetFlow/sFlow) ghi lại siêu dữ liệu (metadata) của các cuộc giao tiếp mạng (IP nguồn/đích, cổng, thời gian, số byte, hướng đi) giống như hóa đơn cước cuộc gọi điện thoại, rất nhẹ và hiệu quả để tra cứu các kết nối bất thường ở quy mô lớn.

Question 54: Domain 4: Security Operations & Forensics

Correct Answer: B

Lập luận chi tiết (Vietnamese Explanation): Thứ tự dễ bay hơi (Order of Volatility) hướng dẫn thu thập dữ liệu từ dễ mất nhất đến bền vững nhất. Thanh ghi (Registers) và Bộ nhớ đệm (Cache) của CPU là nơi dữ liệu thay đổi liên tục theo nano giây, do đó là thành phần dễ bay hơi nhất.

Question 55: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Di chuyển bất khả thi (Impossible Travel) là cảnh báo xảy ra khi một tài khoản đăng nhập thành công từ hai địa điểm địa lý cách xa nhau trong một khoảng thời gian quá ngắn mà không phương tiện vật lý nào có thể di chuyển kịp, báo hiệu tài khoản bị lộ và chia sẻ.

Question 56: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Thực thi cấu hình (Configuration Enforcement) là quá trình tự động hóa việc áp dụng và giữ cho cấu hình hệ thống luôn ở trạng thái chuẩn (baseline). Nếu phát hiện sự sai lệch cấu hình (configuration drift), công cụ quản lý sẽ tự động sửa đổi lại về cấu hình gốc.

Question 57: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Để tránh làm gián đoạn hoặc sập các hệ thống quan trọng hay nhạy cảm (fragile legacy systems), quy trình tốt nhất là chạy thử nghiệm quét lỗ hổng bảo mật trong môi trường thử nghiệm (test environment) giống hệt với môi trường thực tế trước.

Question 58: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Chuỗi cung ứng chứng cứ (Chain of Custody) ghi lại toàn bộ nhật ký tiếp xúc, chuyển giao và lưu trữ vật chứng từ lúc thu thập đến khi đưa ra tòa. Mục tiêu tối thượng của nó là chứng minh vật chứng không bị tráo đổi, sửa đổi, đảm bảo tính pháp lý tại tòa án.

Question 59: Domain 4: Security Operations & Forensics**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Thiết bị chặn ghi (Write Blocker) là công cụ bắt buộc trong pháp chứng số, ngăn chặn mọi lệnh ghi dữ liệu từ máy tính phân tích truyền xuống ổ đĩa vật chứng trong khi vẫn cho phép đọc toàn bộ dữ liệu, bảo toàn nguyên vẹn dấu thời gian và nội dung gốc.

Question 60: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Định dạng nhanh (Quick format) chỉ xóa bảng chỉ mục tệp tin (file allocation table/index) để hệ điều hành đánh dấu không gian đó là trống. Toàn bộ nội dung dữ liệu thực tế vẫn nằm nguyên vẹn trên các khối lưu trữ cho đến khi bị ghi đè, cho phép khôi phục dễ dàng.

Question 61: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Rsyslog hoặc Syslog-ng là các giao thức thay thế syslog truyền thống, hỗ trợ nhiều cải tiến lớn như truyền tải qua TCP tin cậy, mã hóa bằng TLS để bảo mật dữ liệu log trong quá trình truyền tải, và lọc log nâng cao.

Question 62: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Một môi vì cảnh báo (Alert Fatigue) xảy ra khi hệ thống bảo mật tạo ra quá nhiều cảnh báo rác (False Positives) hoặc cảnh báo không khẩn cấp, làm cho các nhà phân tích bị quá tải và có xu hướng lơ đãng hoặc bỏ sót các cuộc tấn công thực sự nghiêm trọng.

Question 63: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Yêu cầu chứa biểu thức logic sai 'AND 1=2' nhằm kiểm tra xem cơ sở dữ liệu có thực thi mã lệnh injected hay không bằng cách xem trang web phản hồi có bị mất nội dung hay không (vì 1=2 luôn sai nên truy vấn không trả về bản ghi). Đây là Blind Content-Based SQLi.

Question 64: Domain 4: Security Operations & Forensics**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Tấn công duyệt thư mục (Directory Traversal) sử dụng toán tử '../' để thoát khỏi thư mục gốc của trang web nhằm truy cập các tệp tin hệ thống nhạy cảm. Cuộc tấn công thành công do cấu hình sai quyền truy cập thư mục của máy chủ web.

Question 65: Domain 4: Security Operations & Forensics**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Đánh cắp phiên (Session Hijacking) qua Session Replay xảy ra khi kẻ tấn công lấy được mã cookie phiên làm việc của nạn nhân và tái sử dụng nó để giả mạo trình duyệt của nạn nhân, truy cập trực tiếp hệ thống mà không cần mật khẩu.

Question 66: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Trình quét lỗ hổng bảo mật (Vulnerability Scanner - như Nessus, Qualys) là công cụ chuyên biệt để quét hệ thống mạng và thiết bị, đối chiếu với cơ sở dữ liệu để tìm ra các lỗi cấu hình, thiếu bản vá hoặc dịch vụ nguy hiểm đang chạy.

Question 67: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): BPDU Guard là tính năng bảo vệ cổng switch, tự động vô hiệu hóa (disable) một cổng được thiết lập cho thiết bị người dùng (edge port) nếu nhận được thông điệp quản lý BPDU từ một switch lạ cắm vào cổng đó, ngăn chặn thay đổi topo STP trái phép.

Question 68: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Phân tích nguyên nhân gốc rễ (Root Cause Analysis - RCA) là một phần của bước 'Bài học kinh nghiệm' (Lessons Learned) trong quy trình phản ứng sự cố, nhằm tìm ra lỗi cốt lõi (con người hoặc kỹ thuật) dẫn đến sự cố để khắc phục triệt để và phòng ngừa tái diễn.

Question 69: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Kiểm thử xâm nhập (Penetration Test) là một cuộc tấn công mô phỏng được ủy quyền và hợp pháp chống lại hệ thống của tổ chức để tìm kiếm và khai thác lỗ hổng thực tế, giúp đánh giá chính xác sức mạnh của hệ thống phòng thủ.

Question 70: Domain 4: Security Operations & Forensics**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Kiểm thử môi trường đã biết (Known Environment hay White box) cung cấp cho kiểm thử viên toàn bộ thông tin chi tiết về sơ đồ mạng, mã nguồn hoặc quyền truy cập của hệ thống trước khi kiểm thử, giúp đánh giá bảo mật toàn diện và tiết kiệm thời gian do thám.

Question 71: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Giám sát tính toàn vẹn của tệp tin (File Integrity Monitoring - FIM) liên tục kiểm tra dấu thời gian và mã băm của các tệp tin hệ thống và tệp cấu hình quan trọng để phát hiện bất kỳ thay đổi trái phép nào do mã độc hoặc tin tặc thực hiện.

Question 72: Domain 4: Security Operations & Forensics**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Diễn tập trên bàn (Tabletop Exercise) là cuộc họp thảo luận lý thuyết dựa trên kịch bản tình huống sự cố cụ thể, giúp các thành viên đội phản ứng sự cố ôn lại vai trò, quy trình giao tiếp và phát hiện các lỗ hổng trong kịch bản ứng phó mà không gây ảnh hưởng đến hệ thống thực tế.

Question 73: Domain 4: Security Operations & Forensics**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Tính toán mã băm (Cryptographic hash) ngay khi vừa thu thập dữ liệu pháp chứng giúp tạo ra một dấu vân tay số duy nhất của tệp tin đó. Mọi thay đổi dù chỉ 1 bit dữ liệu sau đó cũng sẽ làm thay đổi mã băm, giúp phát hiện và chứng minh tính toàn vẹn của chứng cứ.

Question 74: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Giao thức TACACS+ (do Cisco phát triển) sử dụng TCP, mã hóa toàn bộ nội dung gói tin trao đổi và tách biệt hoàn toàn ba chức năng AAA, cho phép quản trị viên kiểm soát chi tiết từng câu lệnh của người dùng trên thiết bị mạng. RADIUS dùng UDP và gộp chung Authentication/Authorization.

Question 75: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Ngăn chặn (Containment) bằng cách cấu hình bộ quy tắc chặn Access Control List (ACL) trên router là hành vi kiểm soát nhanh chóng để giới hạn mức độ lây lan và thiệt hại của một sự cố mạng khi nó đang diễn ra.

Question 76: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Chương trình săn lỗi nhận thưởng (Bug Bounty) là hình thức khuyến khích các chuyên gia bảo mật bên ngoài thử nghiệm xâm nhập hệ thống và báo cáo lỗi một cách có trách nhiệm để nhận phần thưởng tài chính, giúp tổ chức sửa lỗi trước khi bị tin tặc lợi dụng.

Question 77: Domain 4: Security Operations & Forensics**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Yêu cầu lưu giữ chứng cứ pháp lý (Legal Hold hay Litigation Hold) là thông báo bắt buộc tổ chức phải bảo quản và ngừng mọi quy trình xóa tự động đối với các tệp tin, email và bản ghi sao lưu liên quan đến vụ kiện để phục vụ cho quá trình tố tụng.

Question 78: Domain 4: Security Operations & Forensics**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): ExifTool là công cụ dòng lệnh mạnh mẽ dùng để đọc, ghi và sửa đổi siêu dữ liệu (metadata) của nhiều định dạng tệp tin khác nhau, cho phép điều tra viên pháp chứng số trích xuất các thông tin ẩn quan trọng như tọa độ GPS của ảnh chụp.

Question 79: Domain 4: Security Operations & Forensics**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Săn tìm mối đe dọa (Threat Hunting) là quá trình chủ động tìm kiếm các chỉ số xâm nhập (IoCs) ẩn trong hệ thống dựa trên giả định rằng hệ thống đã bị xâm nhập (presumption of compromise), nhằm phát hiện sớm các cuộc tấn công chưa bị phát hiện bởi công cụ tự động.

Question 80: Domain 4: Security Operations & Forensics**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Thời gian sửa chữa trung bình (Mean Time to Repair - MTTR) đại diện cho thời gian trung bình cần thiết để khắc phục sự cố phần cứng/phần mềm và khôi phục hệ thống trở lại trạng thái hoạt động bình thường sau khi sập.

Question 81: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Tiêu chuẩn (Standard) cung cấp các yêu cầu kỹ thuật bắt buộc cụ thể (ví dụ: bắt buộc dùng thuật toán mã hóa nào, độ dài khóa bao nhiêu) để triển khai thực tế các mục tiêu trừu tượng được đặt ra trong Chính sách (Policy).

Question 82: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Thỏa thuận mức dịch vụ (Service Level Agreement - SLA) là cam kết ràng buộc bằng hợp đồng giữa nhà cung cấp dịch vụ và khách hàng, quy định các tiêu chí chất lượng cụ thể (như thời gian hoạt động - uptime) và hình thức bồi thường nếu vi phạm.

Question 83: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Bên kiểm soát dữ liệu (Data Controller) là cá nhân hoặc tổ chức quyết định mục đích và phương pháp xử lý dữ liệu cá nhân của người dùng (Data Subject). Đây là vai trò chịu trách nhiệm pháp lý cao nhất về tuân thủ quyền riêng tư dữ liệu.

Question 84: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Đạo luật về tính khả chuyển và trách nhiệm giải trình bảo hiểm y tế (HIPAA) là luật liên bang của Mỹ bắt buộc các đơn vị y tế, bệnh viện và các bên liên quan phải áp dụng các biện pháp bảo mật chặt chẽ để bảo vệ thông tin sức khỏe cá nhân (PHI).

Question 85: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Chuyển giao rủi ro (Risk Transference) là chiến lược chuyển dịch một phần tác động tài chính hoặc trách nhiệm pháp lý của rủi ro sang một bên thứ ba (như mua bảo hiểm hoặc thuê ngoài dịch vụ), giúp bảo vệ tổ chức khỏi tổn thất trực tiếp.

Question 86: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Né tránh rủi ro (Risk Avoidance) là việc thay đổi mô hình kinh doanh hoặc ngừng hẳn hoạt động thu thập/xử lý dữ liệu nhạy cảm để loại bỏ hoàn toàn khả năng rủi ro đó xảy ra. Biện pháp này triệt để nhưng có thể gây bất tiện cho hoạt động kinh doanh.

Question 87: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Rủi ro còn lại (Residual Risk) là lượng rủi ro vẫn tồn tại sau khi tổ chức đã áp dụng đầy đủ các biện pháp kiểm soát và chiến lược ứng phó rủi ro. Tổ chức phải đảm bảo mức rủi ro còn lại này nằm trong giới hạn chấp nhận được (Risk appetite).

Question 88: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Khẩu vị rủi ro mở rộng (Expansionary Risk Appetite) phản ánh tư thế sẵn sàng chấp nhận các rủi ro bảo mật ở mức độ cao hơn để ưu tiên cho sự tăng trưởng nhanh, thử nghiệm công nghệ mới và giành lợi thế cạnh tranh.

Question 89: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Ngưỡng rủi ro (Risk Threshold) là ranh giới cụ thể được lượng hóa rõ ràng. Khi mức độ rủi ro thực tế vượt qua ngưỡng này, hệ thống sẽ tự động kích hoạt các hành động ứng phó khẩn cấp hoặc báo cáo lên cấp quản lý cao hơn.

Question 90: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Điều khoản quyền được kiểm toán (Right-to-Audit Clause) là thỏa thuận trong hợp đồng cho phép bên mua có quyền tự thực hiện hoặc thuê bên thứ ba độc lập tiến hành kiểm toán bảo mật cơ sở hạ tầng và quy trình của nhà cung cấp dịch vụ.

Question 91: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Biên bản ghi nhớ (Memorandum of Understanding - MOU) là văn bản không mang tính ràng buộc pháp lý chặt chẽ, được dùng để ghi nhận các mục tiêu chung, sự hiểu biết lẫn nhau và kế hoạch hợp tác sơ bộ giữa hai hay nhiều tổ chức.

Question 92: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Ma trận rủi ro hay Bản đồ nhiệt (Risk Matrix / Heat Map) là công cụ trực quan hóa tuyệt vời dành cho ban lãnh đạo, giúp tóm tắt nhanh chóng phân bố các rủi ro theo hai trục Xác suất (Probability) và Tác động (Impact) bằng màu sắc dễ nhận biết.

Question 93: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Thỏa thuận bảo mật thông tin (Non-Disclosure Agreement - NDA) là hợp đồng pháp lý ràng buộc bắt buộc nhân viên hoặc đối tác phải giữ bí mật các thông tin nội bộ nhạy cảm (như mã nguồn, chiến lược kinh doanh) được tiếp cận.

Question 94: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Tiêu chuẩn bảo mật dữ liệu ngành thẻ thanh toán (PCI DSS) là một bộ quy tắc bảo mật bắt buộc toàn cầu được thành lập bởi hội đồng các hãng thẻ (Visa, Mastercard, v.v.). Đây là nghĩa vụ theo hợp đồng chứ không phải luật pháp chính phủ.

Question 95: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Tiêu chuẩn CIS (CIS Benchmarks) phát triển bởi Trung tâm Bảo mật Internet là bộ hướng dẫn cấu hình bảo mật chi tiết và uy tín hàng đầu thế giới được xây dựng bởi sự đồng thuận của nhiều chuyên gia để cấu hình an toàn cho các hệ thống.

Question 96: Domain 5: Security Program Management and Oversight**Correct Answer: B**

Lập luận chi tiết (Vietnamese Explanation): Đạo luật về Quyền giáo dục và Quyền riêng tư của gia đình (FERPA) là luật liên bang của Mỹ nhằm bảo vệ quyền riêng tư của hồ sơ giáo dục học sinh, sinh viên tại các cơ sở giáo dục nhận tài trợ từ chính phủ.

Question 97: Domain 5: Security Program Management and Oversight**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Mô phỏng lừa đảo (Phishing Simulation) là phương pháp thực hành nhận thức bảo mật thực tế bằng cách gửi thư lừa đảo giả định đến nhân viên để đo lường mức độ cảnh giác và tự động đào tạo lại kịp thời những người dùng mắc lỗi.

Question 98: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Nghỉ phép bắt buộc (Mandatory Vacations) là kiểm soát nhân sự quan trọng dùng để phát hiện gian lận. Khi nhân viên vắng mặt dài ngày và bị ngắt quyền truy cập, các hoạt động che giấu gian lận của họ sẽ bị gián đoạn và dễ bị người thay thế phát hiện.

Question 99: Domain 5: Security Program Management and Oversight**Correct Answer: A**

Lập luận chi tiết (Vietnamese Explanation): Tiêu chuẩn ISO 27001 là bộ tiêu chuẩn quốc tế quy định các yêu cầu đối với việc xây dựng, triển khai và vận hành Hệ thống quản lý an toàn thông tin (ISMS) trong tổ chức. ISO 27701 là mở rộng cho quyền riêng tư dữ liệu.

Question 100: Domain 5: Security Program Management and Oversight**Correct Answer: C**

Lập luận chi tiết (Vietnamese Explanation): Quy trình ứng phó hay Kịch bản ứng phó (Procedure / Playbook) cung cấp hướng dẫn hành động từng bước một (step-by-step checklist) rất chi tiết để xử lý một tình huống cụ thể, đảm bảo hành động của cả đội luôn nhất quán và chính xác.